SRI LANKA INSTITUTE OF INFORMATION TECHNOLOGY

FACULTY OF COMPUTING.

WEB SECURITY- IE2062

IT22121592 – HERATH H.M.C.H.K

Y2S2

Contents

Subdomain Enumeration: 3
Vulnerability title: 3
Vulnerability description: 4
Affected components. 5
Impact assessment 7
Step to reproduce: 9
Proposed mitigation or fix: 11

Subdomain ‘account.bigcommerce.com’

Subdomain Enumeration:

```
└─$ dig account.bigcommerce.com @8.8.8.8

; <<>> DiG 9.19.21-1-Debian <<>> account.bigcommerce.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 47093
;; flags: qr rd ra; QUERY: 1, ANSWER: 3, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;account.bigcommerce.com.       IN      A

;; ANSWER SECTION:
account.bigcommerce.com. 900    IN      CNAME   manage.bigcommerce.com.
manage.bigcommerce.com. 900     IN      CNAME   shared-lb-lb1.gcp.bigcommerce.net.
shared-lb-lb1.gcp.bigcommerce.net. 300 IN A     35.227.219.245
```

Vulnerability title:

Exposing a system by opening ports 80 (HTTP) and 443 (HTTPS) can lead to vulnerabilities because of the services operating on these ports. Here's an overview of the risks linked to having these ports open;

Vulnerability description:

Port 80 (HTTP):

Data Interception Warning: When using HTTP communication channels, without encryption measures in place leaves information to interception by parties. This puts at risk data such, as login details and personal information.

Man, in the Middle Attacks (MitMs): Due to the lack of encryption in HTTP protocol usage opens up the possibility for attackers to engage in MitMs attacks by intercepting and modifying communication, between the client and server.

Cross-site scripting (XSS): When websites are accessed over HTTP there is a risk of Cross Site Scripting (XSS) attacks if they fail to filter user input for any scripts that attackers might insert into pages to target other users who view them.

Insecure cookies: When cookies are sent over HTTP without encryption security measures, in place (such, as encryption) they can be. Exploited for session hijacking purposes.

Port 443 (HTTPS):

Misconfigured SSL/TLS: Improperly set up SSL/TLS settings can result in security risks, like SSL stripping which involves attackers downgrading the connection, to HTTP when HTTPS is not configured correctly.

Expired or Invalid Certificates: When expired or invalid SSL/TLS certificates are used it can give a sense of security. Leave users vulnerable, to phishing attempts.

Cipher Suite Vulnerabilities: Weak cipher suites could potentially be exploited during the TLS handshake process. Resulting in security vulnerabilities such, as the POODLE or BEAST attacks.

Information leakage: When using HTTPS encryption to secure data transmission on websites or applications confidential information may still be unintentionally exposed through error messages incorrectly set headers or mishandling of redirects.

Affected components.

Ports 80, for HTTP, and 443, for HTTPS being open, can impact parts of a web application and its infrastructure Let's explore the components that might be influenced by this setup;

Web server:

Issues: within the web server software like Apache Nginx or IIS can leave the application vulnerable to types of attacks, like denial of service (DoS). It could also make it easier for attackers to exploit known vulnerabilities in the server itself.

Web-based application:

Coded applications may result in security risks, like SQL injection or Cross Site Request Forgery (CSRF).

Using vulnerable third-party libraries can pose security risks when they are accessed through these ports.

Network infrastructure:

Misconfigured firewalls might lead to access, through these ports. Put the network at risk of potential attacks.

Improperly configured load balancers could potentially pose security risks by permitting traffic to access the servers behind them.

Client-side components:

When using web browsers to visit websites, HTTP users may face security risks due, to insecure connections as browsers themselves can have vulnerabilities that put users at risk when they visit compromised sites.

Web based applications are vulnerable, to security threats when operating on the internet through HTTP or HTTPS connections without adequate protective measures in place.

Database servers:

If a program has security weaknesses, Utilizes direct database queries that are susceptible, to exploitation by hackers, through web application vulnerabilities.

APIs:

Open ports that are utilized by RESTful and GraphQL APIs may be vulnerable, to access if they do not have authentication and authorization safeguards, in place; this could result in potential data breaches.

Session Control:

Unauthorized access can occur when open ports are not properly protected, enabling session hijacking if adequate security measures, such, as using cookies are not, in place.

SSL/TLS configuration:

SSL/TLS Certificate Handling Concerns; Poor handling of SSL/TLS certificates can lead to security risks when certificates are not properly configured or have expired.

Impact assessment.

Impact Assessment of Open Ports 80 and 443

The moment's thinking around open ports 80 (HTTP) and 443(HTTPS) is leaving the door of your house unlocked: Though it seems a trivial matter, the consequences if someone walks in, could be dire. Let us explore the scenarios if these vulnerabilities are exploited.

1. Business Impact

Financial Loss: Consider this situation, a user, a hacker, breaks into your system, absconds with customer data, or compromises your services. This may result in financial losses, which are the direct results of losing stimulated funds or economic expenditure attempts in retargeting measures and costly repair activities

Reputation Damage: It is clear that trust is very crucial in business relationships. When customers learn of a breach, there is likelihood that they will think of 'Maybe it is best to leave the company. If they can't keep my information safe' Such a situation would result in loss of existing dominants and difficulties in obtaining new ones.

Regulatory Penalties: Every business has to contend with laws, and for those dealing with data protection laws on a broad scale (like GDPR), a breach might lead to extravagant penalties and heightened scrutiny from regulators. This is needless pressure!

2. Operational Impact

Service Disruption: In the case of a successful attack, it is likely that your site will go offline. This would annoy customers who are trying to just pay for something or check information. This kind of downtime can result in sales that could have been made, as well as one that does not present great value to the end-users.

Resource Allocation: In case a breach does occur, it is conceivable that there will be a need to reassign staff members from their competencies to manage the breach. This will then adversely impact the timelines of other key projects, thus leading to efficiency loss.

3. Technical Impact

Data Breaches: Confidential data such as addresses and payment details owned by customers could also be compromised. Such a situation is not just inconveniencing but also has ramifications to the victims.

Infrastructure Compromise: When hackers successfully infiltrate your networks, chances that they will remain in just that one sector is rather slim. They may go over your whole infrastructure, making even more harm and disorder.

Malware Deployment: Weaknesses may allow malicious players to penetrate your systems with dangerous software which may bring more issues in future.

4. Customer Impact

Loss of Trust. When a customer believes their details are not in safe hands, there is a likelihood that they will not come back. Trust is something that is almost impossible to build back with the customer, and is going to drastically affect how customers view the brand in the long run.

Compensation and Legal Claims. When the justice system fails them, and their interaction with the organization had adverse effects, customers will not only seek compensation but sue as well. Such actions are not only costly but takes a huge toll on the brand image.

5. Compliance and Legal Impact

Investigations and Audits. Following an illicit event, the organization is most likely to engage with supervisory bodies which can be time wasting and expensive as the investigations are often thorough and extensive.

Litigation. There are possibilities of engaging in clashes in court with affected clients which brings in more stress and cost implications.

6. Long-term Strategic Impact

Market Position. Radical cases of breaches can have unfavorable repercussions- from the prospective customers point of view which can be very dangerous inefficiencies from the competitor's point of view, chances are they are going to take the opportunity and cause significant loss of market share.

Change in Business Strategy. After a breach, a lot of money will need to be injected in the organization to fix losses, which will have a negative influence on other crucial plans the organization had already positioned.

Step to reproduce:

```
└─$ dig account.bigcommerce.com @8.8.8.8

; <<>> DiG 9.19.21-1-Debian <<>> account.bigcommerce.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 47093
;; flags: qr rd ra; QUERY: 1, ANSWER: 3, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;account.bigcommerce.com.       IN      A

;; ANSWER SECTION:
account.bigcommerce.com. 900    IN      CNAME   manage.bigcommerce.com.
manage.bigcommerce.com. 900     IN      CNAME   shared-lb-lb1.gcp.bigcommerce.net.
shared-lb-lb1.gcp.bigcommerce.net. 300 IN A     35.227.219.245
```

```
* IPv4: 35.227.219.245
*   Trying 35.227.219.245:443...
* Connected to account.bigcommerce.com (35.227.219.245) port 443
* ALPN: curl offers h2,http/1.1
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
*  CAfile: /etc/ssl/certs/ca-certificates.crt
*  CApath: /etc/ssl/certs
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384 / X25519 / RSASSA-PSS
* ALPN: server accepted http/1.1
* Server certificate:
*  subject: C=US; ST=Texas; L=Austin; O=BigCommerce, Inc.; CN=*.bigcommerce.com
*  start date: Mar  8 00:00:00 2024 GMT
*  expire date: Mar  6 23:59:59 2025 GMT
*  subjectAltName: host "account.bigcommerce.com" matched cert's "*.bigcommerce.com"
*  issuer: C=US; O=DigiCert Inc; CN=DigiCert Global G2 TLS RSA SHA256 2020 CA1
*  SSL certificate verify ok.
*   Certificate level 0: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
*   Certificate level 1: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
*   Certificate level 2: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
* using HTTP/1.x
> GET / HTTP/1.1
> Host: account.bigcommerce.com
> User-Agent: curl/8.5.0
> Accept: */*
>
* TLSv1.3 (IN), TLS handshake, Newsession Ticket (4):
* TLSv1.3 (IN), TLS handshake, Newsession Ticket (4):
* old SSL session ID is stale, removing
< HTTP/1.1 302 Found
< Content-Type: text/html; charset=utf-8
< Transfer-Encoding: chunked
< Connection: keep-alive
< location: https://account.bigcommerce.com/sign_in
< cache-control: no-cache
< set-cookie: _session_id=023f6052d1b758bbbb32d1d8266301e1; path=/; HttpOnly
< x-request-id: 7e37a26f666e25a5c052ec734ffee6ff
< x-runtime: 0.024216
< x-rack-cache: miss
< x-envoy-upstream-service-time: 29
< Strict-Transport-Security: max-age=31536000; includeSubDomains
```

```
└─$ curl -v https://account.bigcommerce.com
* Host account.bigcommerce.com:443 was resolved.
* IPv6: (none)
* IPv4: 35.227.219.245
*   Trying 35.227.219.245:443...
* Connected to account.bigcommerce.com (35.227.219.245) port 443
* ALPN: curl offers h2,http/1.1
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
*  CAfile: /etc/ssl/certs/ca-certificates.crt
*  CApath: /etc/ssl/certs
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
```

```
└─$ nmap -sV -p- account.bigcommerce.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-18 21:08 +0530
Nmap scan report for account.bigcommerce.com (35.227.219.245)
Host is up (0.057s latency).
rDNS record for 35.227.219.245: 245.219.227.35.bc.googleusercontent.com
Not shown: 65533 filtered tcp ports (no-response)
PORT    STATE SERVICE   VERSION
80/tcp  open  http
443/tcp open  ssl/https
2 services unrecognized despite returning data. If you know the service/version, plea
```

Proposed mitigation or fix:

To ensure unrestricted access to Ports 80 (HTTP) and 443 (HTTPS) and defend lost …, the following is a tabulated summary of recommendations and remedies proposed by stakeholders:

Make HTTPS an Absolute Requirement:

- Make a shift from HTTP to HTTPS: All traffic must be sent over HTTPS only, to make sure the data is encrypted and secure from Man-in-the-Middle (MitM) attacks. Redirect any page requesting HTTP to HTTPS pages using 301 redirects.
- Establish All Valid SSL/TLS Certificates: To facilitate communication, a valid SSL/TLS certificate needs to be obtained and installed. It is good practice to renew expired certificates and configure them so that they don't run out.
- Ensure HTTP Strict Transport Security HSTS is enabled: Attackers mount such attacks by launching a MitM upon which they make the user go unaware of HTTP

Secure SSL/TLS Configuration

- Disable Weak Protocols and Ciphers: Disabling weak protocols such as SSLv2 or SSLv3 and only allowing TLS v 1.2 v 1.3 versions or even later. Weak cipher suites such as RC4 and MD5 should also be removed.
- Use Perfect Forward Secrecy (PFS): Selecting to use PFS means that even if a session key itself is intercepted, that session key alone wouldn't affect any dependent sessions.
- Regularly Test Your SSL/TLS Setup: There are various tools, such as SSL Labs, that can help you in testing your SSL or TLS and its relative configuration.

Web Application Security

- Implement Secure Coding Practices: Your web application should implement secure coding practices so as to avoid vulnerabilities such as Cross-Site Scripting(XSS), SQL injection and other OWASP Top 10 vulnerabilities.
- Sanitize User Input: Injections like SQLi, XSS should not be successful by always sanitizing and validating any input from users.
- Use Content Security Policy (CSP): Deploy a CSP header to protect a user's browser in case the user visits any foreign links that contain malicious scripts or codes
- Secure Cookies: Cookies should be marked as Secure, HttpOnly, and SameSite to prevent interception and cross-site scripting attacks.

Firewall Configuration

- Restrict Access to Open Ports: Only services that are necessary should have access to ports 80 or 443. Firewalls can also be configured in such a way as to only allow IPs that are trusted or bloc abusive conduct.
- Set Up a Web Application Firewall (WAF): Enable a WAF which can shield a website from common web vulnerabilities such as XSS and SQL injection as well as other forms of attacks by monitoring and filtering traffic.